

Passwordless 2025



MIKA VILPO

IT GEEK BUILDING CLOUDS

@NETOX OY

LIKES TO TALK ABOUT IDENTITY, AUTOMATION AND SERVERLESS
25+ YEARS IN IT AND 15+ YEARS IN CLOUD

SPENDING FREE TIME AS RED CROSS VOLUNTEER IN
DISASTER MANAGEMENT, FIRST AID AND SEARCH & RESCUE

MIKA.VILPO@NETOX.COM

@MIKAVILPO 





What are we talking about today?

Passwordless

Old Stuff

Passkeys

Where can we use this stuff?

What should you do?

What is Passwordless Authentication?



AUTHENTICATION METHODS NOT
RELIANT ON PASSWORDS



BENEFITS:
SECURITY, USABILITY, COST



EXAMPLES:
WINDOWS HELLO, FIDO2, PASSKEYS,
MICROSOFT AUTHENTICATOR

Current State (11.12.2025)



- Entra ID supports
 - Device Bound Passkeys
 - Synced Passkeys (preview)
 - Windows Hello for Business
 - Authenticator App
 - Certificates
 - on smartcards
 - on smartcard emulators
 - Temporary Access Pass (TAP)
- Most "real" web services support passkeys
- Google, Apple, Microsoft aligned on passkeys

What's Sunsetting / Deprecated

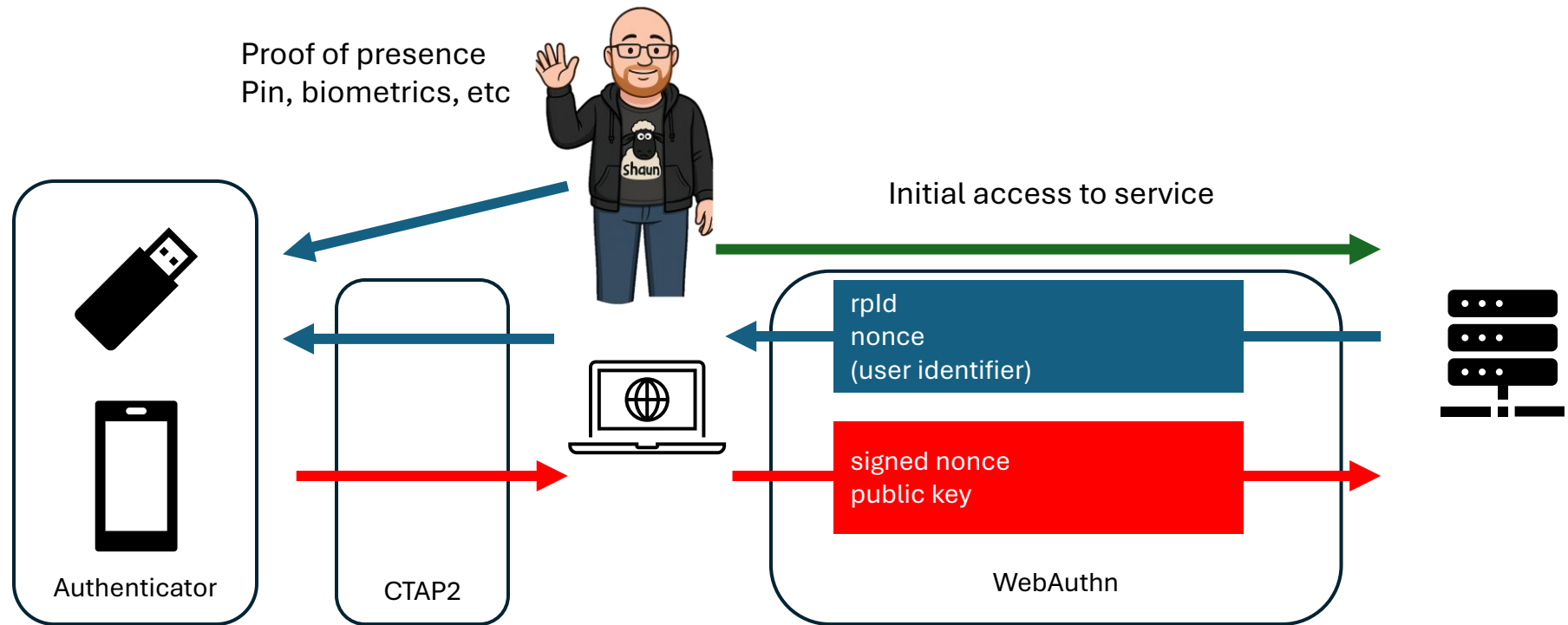
- SMS and voice-based MFA are being deprecated in best practices
- Legacy MFA settings phased out
- Legacy Multifactor Authentication (MFA) and Self-Service Password Reset (SSPR) Policies
 - Converged Policy

Passkeys

FIDO2 is a broad authentication standard enabling passwordless login using hardware or biometric credentials, while passkeys are a user-friendly implementation of FIDO2 credentials that sync across devices and are designed to replace passwords entirely.

- Phishing resistant by design
- Public/private key pair: user device holds private key
 - Unique for each service
- Auth with biometric/PIN, no shared secret
 - Something you have (passkey) and something you know (PIN) or something you are (biometrics)
- Domain binding prevents replay attacks (discoverable FIDO2 → Passkey)
- Can be stored (with Entra ID support)
 - External device (USB, Bluetooth)
 - Microsoft Authenticator
 - 3rd party password wallet (preview)
 - Windows Hello
 - (Windows Hello for Business)

Passkey authentication flow (simplified)



RP ID (hashed)	Private Key	Public Key	User identifier
https://site1.com	1234	2345	foo@bar.fi
https://site2.com	3456	4567	foo@bar.fi
https://site1.com	5678	6789	admin@bar.fi

Public Key	Username
2345	foo@bar.fi
6789	admin@bar.fi

Passkey Support in Entra

Credential Type	Entra Support	State	Notes
FIDO2 Security Keys (device-bound)	✓	GA	High assurance, full attestation support.
Microsoft Authenticator Passkeys (device-bound)	✓	GA	Stored in device secure hardware No cloud sync yet.
Synced Passkeys – Apple, Google, Microsoft, 3rd party Password Manager	✓	Public Preview (Ignite 2025)	Private key synced via platform vendor cloud Attestation not possible.
Windows Hello for Business (platform)	✓	GA	Not managed through Passkey (FIDO2) settings.
Authenticator Phone Sign-In (non-passkey)	✓	GA	Push-based, not FIDO.

Passkeys? FIDO2? Roaming? I'm confused.

Term	Technical meaning	Interchangeable with	Not the same as	Notes
Passkey	WebAuthn credential with discoverability + user verification	FIDO2 discoverable credential	Non-discoverable FIDO2 credential	User-friendly term. May be multi-device or device-bound
Synced Passkey	Private key synced via cloud provider (Apple, Google, Microsoft)	Multi-device credential, cloud-synchronized passkey	Device-bound passkeys	Great UX, weaker provenance/attestation
Device-Bound Passkey	Private key stays on one authenticator; no sync	Single-device credential	Synced passkey	Higher assurance (hardware-backed)
Discoverable Credential	Stored on authenticator + discoverable without username.	Resident credential, usernameless	Non-discoverable credential	All passkeys are discoverable credentials
Roaming Authenticator	External authenticator (USB/NFC/BLE).	Security key, cross-platform authenticator	Platform authenticator	Holds device-bound passkeys
Platform Authenticator	Built-in authenticator (TPM, Secure Enclave)	Windows Hello, Touch ID, Android Biometrics	Roaming key	Can store synced or device-bound passkeys depending on provider
FIDO2 Security Key	Hardware CTAP2 authenticator implementing WebAuthn	Roaming authenticator	Smart card, OTP token	Almost always device-bound
Attestation	Cryptographic proof of authenticator model & hardware identity	Authenticator attestation		Enterprise control mechanism
Enterprise Attestation	Enhanced attestation providing serial number/corporate ownership (Opt-in)		Standard attestation	Security keys rarely allow this unless explicitly configured
Passwordless	Any method without password		"Passkey"	Includes WHfB, Authenticator phone sign-in, but not a synonym for passkeys

Microsoft Ignite 2025: What's New for Entra Passkeys

Synched Passkeys for Work Accounts (Preview)

- Entra ID can register **synched passkeys** from:
 - iCloud Keychain
 - Google Password Manager
 - Microsoft Account (Windows)

Authentication Strength Updates

- New "Phishing-resistant" strength category includes:
 - Device-bound passkeys (hardware or WHfB)
 - Synched passkeys (if chosen)
 - Authenticator passkeys

Passkey Profiles (Preview)

- Configure multiple passkey profiles, targeting groups individually.
- Examples
 - *Admins* → device-bound only
 - *Employees* → synched + device-bound
 - *Contractors* → security key only
- Supported attributes per profile:
 - Allowed passkey type: **Device-Bound / Synched / Both**
 - Allowed authenticators
 - Attestation enforcement settings

Attestation?

Attestation is the method of controlling which hardware keys are allowed.

Basic Attestation

- Authenticator provides a manufacturer-signed certificate describing the device model.
- Enterprise use:
 - Block fake/unknown keys
 - Allowlist YubiKeys, FEITIAN, TrustKey, etc.

Self Attestation

- Authenticator signs with the new credential itself → unenforceable for enterprise.
- Many mobile platform authenticators default to this when privacy settings block attestation.

Enterprise Attestation

- Provides unique device identifiers (e.g., serial numbers) after explicit opt-in by admin.
- Use cases:
 - Bind key to an employee physically
 - Hardware lifecycle management

Anonymized Attestation (Privacy-Aware)

- Apple/Google platform authenticators remove unique hardware ID.
- Synced passkeys cannot produce attestation at all (cloud key architecture).

Entra control layers for Passkeys

Layer 1: Attestation Enforcement

- Entra setting: “**Enforce Attestation: Yes/No**”
- If **Yes**:
 - Only device-bound keys with valid attestation allowed
 -  Synced-passkeys
 -  Security keys with no known-metadata

Layer 2: Authenticator Allowlist / Blocklist

- Based on attestation metadata:
 - Allow only specific AAGUIDs e.g., YubiKey 5 series
 - Block consumer roaming keys

Layer 3: Passkey Type Controls (Preview)

- Choose **Device-bound**, **Synced**, or **Both** per profile.

Layer 4: Conditional Access

- Use **Authentication Strengths**:
 - Require “Phishing-resistant MFA”
 - Hardware FIDO2
 - WHfB
 - Authenticator passkey
 - Synced passkeys (if enabled)

Layer 5: Registration Controls

- Enforce:
 - MFA before registration
 - Allowed devices

When Should You Allow Synced Passkeys vs Device-Bound?

Scenario	Recommended Passkey	Reason
Admins / Privileged Roles	Device-bound only	Need attested hardware + no cloud copy.
General knowledge workers	Synced + device-bound	Best user experience.
Contractors / BYOD	Device-bound only	No corporate data synced to personal cloud ecosystems.
Regulated workloads	Device-bound + attestation required	High trust and audit requirements.

How can we use these Passkeys with Entra ID?

External device (USB, NFC, Bluetooth) aka. Security Key

- USB-stick, FIDO2 with Bluetooth

Microsoft Authenticator (on Android or iOS)

- Locally on mobile device
- Via Bluetooth on different device
- NB: Does not require device registration on Entra ID

Windows Hello

- Used in background for WHfB, keys visible but not creatable in UI.

Platform Credential (Mac OS)

3rd party authenticators (PREVIEW)

- Can sync passkeys between devices



Where can we use Passkeys with Entra ID?

- Web applications
- Apps that use modern authentication
- Windows login via Web sign-in credential provider
 - Enables also TAP support
 - NB: Only Entra Joined devices supported
 - NB: Requires internet
- Security key (USB etc.) works with Windows login

Near-Future & Preview Features (Entra ID)

Public preview

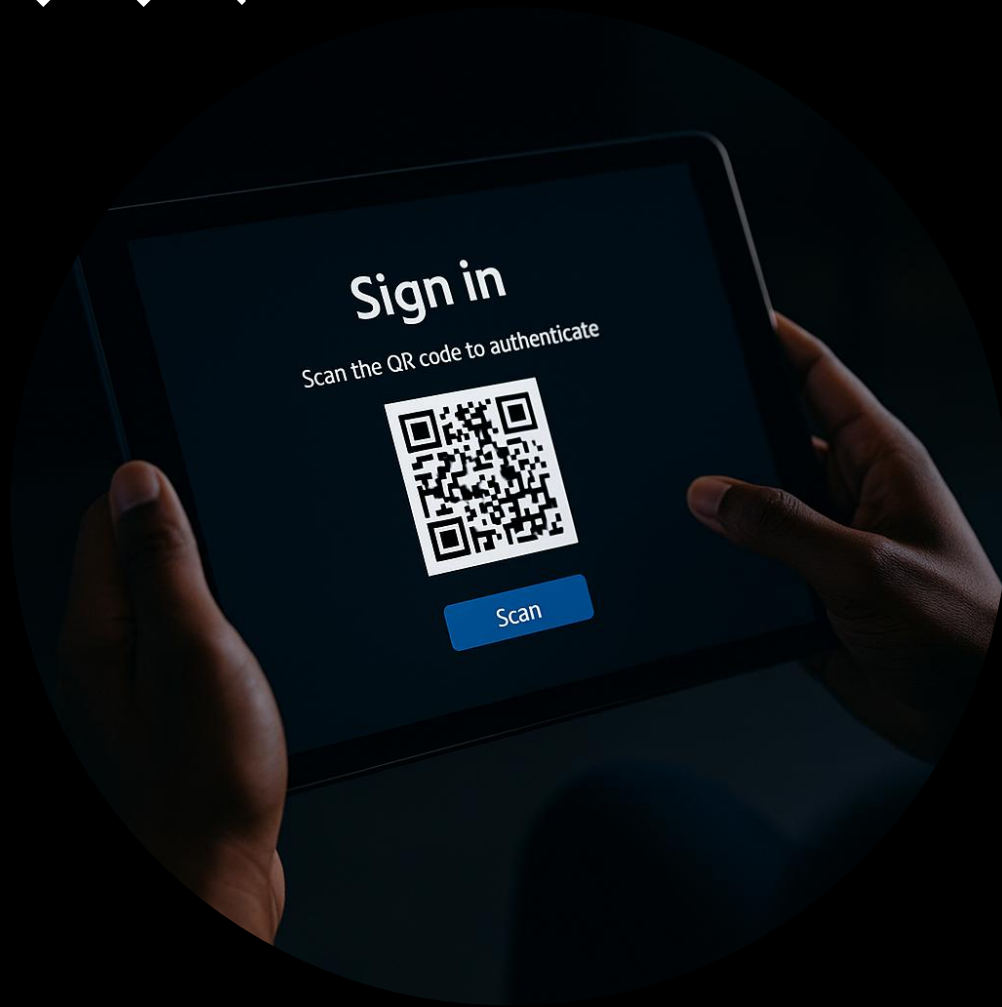
- Device-bound passkeys on mobile devices
 - Roaming/synced Passkeys
 - Passkeys on 3rd party password manager
 - QR codes for first line workers
-
- Provision Passkeys on behalf of user

Microsoft Entra ID currently supports only device-bound passkeys stored on FIDO2 security keys or in Microsoft Authenticator. Microsoft is committed to securing customers and users with passkeys, and **plans to support synced passkeys for Microsoft Entra ID.**



QR codes for first line use cases

- QR-code + PIN
- Considered as single factor authentication
- Works only on mobile devices
 - Shared devices, kiosk modes
 - *Login to warehouse handheld device*
- QR scan → PIN → session
- Think twice before enabling



Passkeys and RDP



Client Windows 10/11 (22H2) and Windows Server 2022+ that is Entra joined/hybrid joined are good to go



Azure Virtual Desktop, Windows 365 and DevBox are good to go
(at least when using native clients, not web)



In session (WebAuthn redirect) is supported with Windows Server 2022+



No mobile device support

Authentication Strengths

- Can define what authentication methods are usable and when
 - Works with Conditional Access and Authentication Context
- Whitelist/blacklist what passwordless methods are allowed and what are not
- Whitelist/blacklist passkey types
- **PIM:** Global Admin requires approved FIDO2 device
- **Protected Actions:** Deletion of objects requires Phishing Resistant authentication

☐	▼	Phishing-resistant MFA (3)
☐		Windows Hello For Business / Platform Credential
☐		Passkeys (FIDO2) Advanced options
☐		Certificate-based Authentication (Multifactor) Advanced options
☐	▼	Passwordless MFA (1)
☐		Microsoft Authenticator (Phone Sign-in)

User Adoption Strategy



Enable passwordless methods to everybody to use



Pilot with IT/security champions



Train and communicate benefits



Think what methods to boost for different personas

What should I do?

- **Enable possibility to use passwordless**
- Evaluate what is coming
- It's all about communication to the users
- **Secure (at least) admin actions with phishing resistant authentication**



SpreeView



Review my Session

Questions?

Thank You!



SpreeView



Review my Session



Resources & References

- Microsoft: <https://aka.ms/passwordless>
- FIDO Alliance: <https://fidoalliance.org>
- Passkeys: <https://www.passkeys.dev>
- Entra Auth Strengths: <https://learn.microsoft.com/en-us/entra/id-protection/howto-authentication-strengths>
- Phishing-Resistance: <https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-strengths#phishing-resistant-mfa>
- RDP Passwordless: <https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-plan-rdp-phishing-resistant-passwordless-authentication>